AJ SMART BIZ · DOCUMENT 08

Security & Data Protection

Controls implemented in the code, the threat model they address, and the gaps to close before scale.

Audience	Technical leads, security reviewers, DevOps, business owners
Version / date	1.0 · 7 November 2026

Contents

1. Security principles
2. Identity and access
3. Tenant isolation
4. Input, output and transport
5. Uploads and storage
6. Public endpoints and abuse
7. Data protection and privacy
8. Threat model summary
9. Gaps and recommendations
10. Production hardening checklist

1. Security principles

1. **Derive, don't trust.** Tenant, prices, addresses and the customer's identity are derived on the server; the client sends ids and quantities only.
2. **Guard at the module.** Scope guards are mounted once per route module, so new routes inherit protection.
3. **Absent, not hidden.** A feature that is not live is `null` in the payload — not hidden with CSS — so a lapsed tenant's data never appears in page source.
4. **Fail closed.** No plan means blocked, not unlimited; unknown hosts get platform defaults, not errors that confirm existence.

2. Identity and access

Control	Implementation
Password storage	bcrypt (cost `BCRYPT_SALT_ROUNDS`, default 10) in model hooks; password excluded by default scope.
Tokens	JWT access (default 1 day) and refresh (7 days) with separate secrets; scope in payload. Production boot refuses placeholder secrets.
Session validity	Principal reloaded on every request; inactive/deleted user or inactive company is rejected immediately.
Login throttling	30 attempts per 15 minutes per IP on login routes.
Forced change	Generated main-admin passwords set `mustChangePassword`; the console blocks all routes until changed.
RBAC	Role × menu × five actions enforced by `requirePermission` on the API; UI mirrors it.
Privileged accounts	Root super admin (`isRoot`) and company main admin cannot be deleted or disabled.
Customer auth	Phone + 6-digit OTP, hashed, 10-min expiry, 5 attempts, 10 requests/15 min; token in httpOnly, secure (prod) cookie on the website server; account pages are server-rendered.

3. Tenant isolation

- Admin routes read `companyId` from the token; URL/body company ids are ignored for admins.
- Every query is scoped by company; another tenant's id returns a generic 404.
- Uploads can be deleted only within the caller's own company.
- Public tenant endpoints resolve the company from the host; an unknown/inactive host returns platform defaults, preventing enumeration.

- Customers are unique per company — the same phone at two shops is two unrelated accounts.
- Platform-wide views (cross-tenant leads/customers) exist only under `/super-admin` and are read-only.

4. Input, output and transport

Validation	Joi on params, query and body with `stripUnknown` and type conversion; sort fields allow-listed.
SQL injection	Sequelize parameterised queries; raw fragments use fixed column names only.
Headers	helmet defaults; `trust proxy` for correct client IPs behind nginx.
CORS	Allow-list from `CORS_ORIGINS`; `*` intended only for dev tunnels.
Body size	JSON 2 MB in the API; nginx limits per vhost (2–25 MB).
Transport	TLS via certbot on every public domain; containers talk on a private Docker network.
Errors	Stack traces only outside production.
XSS	Blog bodies stored as plain text; Angular and React escape output by default.

5. Uploads and storage

- Image MIME types only; favicons verified by ICO magic bytes.
- Random filenames (`{base36 time}-{hex}.ext`) in fixed folders; no user-chosen paths.
- `/uploads` served with `Content-Security-Policy: default-src 'none'` and `nosniff`, so an SVG cannot execute script.
- Per-company storage quota enforced on upload; ledger in `company_files`; replaced images deleted.
- The theme `/uploads` proxy rejects `..` path segments.

6. Public endpoints and abuse

Endpoint	Protection
Orders	15/h per IP; server-side pricing; quantity and line caps; feature must be active and route usable.
Service leads / bookings	12/h; slot capacity checked server-side.
Testimonials	5/h; held as *pending* until moderated.
Customer auth	10/15 min; `registered` flag reveals existence only (deliberate trade-off), barred customers look registered.

Endpoint	Protection
Tracking beacons	300/5 min; body capped at 32 KB by the site proxy; failures swallowed.
Marketing enquiries	10/15 min.

7. Data protection and privacy

Data	Where	Notes
Admin and staff identities	admins, super_admins	Email, phone, hashed password.
Customer PII	customers, customer_addresses, orders, service_leads	Name, phone, email, addresses; addresses copied onto orders.
Visitor tracking	leads, lead_visits, marketing_leads	Device id, IP, user agent, UTM, optional browser geolocation (asked once).
Business data	company tables	GST/PAN never returned on public endpoints.

- Order history returned to customers strips internal notes and provenance.
- Soft delete keeps personal data recoverable — a data-erasure procedure (hard delete/anonymise on request) is *not* implemented.
- Team cards' contact details are optional and labelled as published.

> **Compliance note**
>
> Tracking with IP and geolocation, plus customer accounts, makes the tenants data fiduciaries under India's DPDP Act 2023. Add a privacy notice and consent to the website templates and a documented erasure process before scaling.

8. Threat model summary

Threat	Mitigation	Residual risk
Cross-tenant data access	Company from token; scoped queries	Low
Price tampering	Server-side pricing	Low
Credential stuffing	Login rate limit, bcrypt	Medium — no MFA, no lockout
OTP brute force	Attempts + expiry + rate limit	**High until SMS gateway** — dev code is predictable

Threat	Mitigation	Residual risk
Malicious upload	MIME filter, CSP on /uploads, random names	Low
Token theft (consoles)	HTTPS; short access token	Medium — tokens in localStorage
Spam via public forms	Rate limits, moderation	Medium — no CAPTCHA
Tenant enumeration	Defaults for unknown hosts	Low

9. Gaps and recommendations

1. **Connect an SMS gateway** before enabling customer accounts on any live tenant; unset `CUSTOMER_OTP_DEV_CODE` in production.
2. Implement refresh-token rotation in the consoles (refresh token is stored but unused), or shorten access tokens.
3. Consider moving console tokens from localStorage to httpOnly cookies, and add MFA for super admins.
4. Add account lockout / progressive delay per user, not only per IP.
5. Add CAPTCHA or proof-of-work to public enquiry, review and order forms.
6. Remove the default super-admin password from `.env.development` history and ensure production uses unique secrets.
7. Add audit logging for admin actions beyond subscriptions and stock (who changed prices, roles, permissions).
8. Automated dependency scanning (npm audit / Dependabot) and an automated test suite in CI.
9. Encrypted, off-site backups of MySQL and the uploads volume with restore drills.

10. Production hardening checklist

☐	Item
☐	Unique `JWT_SECRET` / `JWT_REFRESH_SECRET`; strong `SUPER_ADMIN_PASSWORD`, changed after first boot
☐	`DB_SYNC_MODE` = alter or none (never force); database user with least privilege
☐	`CORS_ORIGINS` lists exact console origins; `ALLOWED_ORIGINS` empty
☐	`CUSTOMER_OTP_DEV_CODE` unset; SMS gateway configured
☐	`TENANT_DOMAIN` unset on theme containers
☐	Persistent volume for `/app/uploads`; backups scheduled
☐	TLS on every domain; HTTP redirects to HTTPS
☐	Server firewall: only 80/443 (and SSH) open; container ports bound to localhost